

Implementação e utilização de uma PKI Local

As ligações a um servidor Web, usando o protocolo HTTP, não são seguras. Num outro guião mostrou-se a realização de um ataque em que o atacante conseguiu observar o conteúdo das páginas HTTP que uma vítima acedeu.

O protocolo HTTPS, visa tornar seguras as ligações entre um browser e um servidor Web, dotando-as de três propriedades de segurança: confidencialidade, integridade e autenticação. Para se poder configurar um servidor Web para disponibilizar as suas páginas através de HTTPS, é necessário um certificado emitido para o servidor.

Neste guião, pretende-se que use a PKI Local, que criou numa aula anterior, para emitir certificados para servidores e (ii) configure um servidor Web, Apache, para disponibilizar as suas páginas através de ligações utilizando o protocolo HTTPS.

Para isto vai precisar de usar uma máquina Linux para funcionar como servidor, por exemplo a máquina virtual Ubuntu que usou em trabalhos anteriores. Caso não tenha criado a PKI Local, pode pedir a um colega seu que o tenha feito, para emitir os certificados que vai necessitar.

1. Instalação e configuração de um Servidor Web

O primeiro passo é instalar um servidor Web. Um dos serviços de segurança que o SSL/TLS fornece é a autenticação do servidor, o que implica que o servidor tenha um par de chaves assimétricas com a respetiva chave pública certificada (certificado X.509v3). Assim, nesta secção vamos gerar um par de chaves para o servidor e emitir um certificado para a sua chave pública usando a CA Subordinada.

O servidor HTTPS que vamos usar é um servidor Apache, que deve instalar usando o comando:

```
$ sudo apt-get install apache2
```

1.1 Geração do par de chaves para o servidor Web

Para a geração do par de chaves para o servidor HTTPS, vamos usar o OpenSSL, disponível através da linha de comandos. Use o seguinte comando para gerar um par de chaves para o algoritmo RSA de 2048 bits, cifrar a chave privada gerada usando o algoritmo Triple-DES e guardar o par de chaves gerado no ficheiro server.key na sua pasta corrente:

```
$ openssl genrsa -aes-128-cbc -out server.key 2048
```

1.2 Criação de um Pedido de Certificado (CSR)

Use agora o seguinte comando para criar um pedido de certificado de chave pública (CSR) para o servidor, que ficará guardado no ficheiro “server.csr” na sua pasta corrente:

```
$ openssl req -new -key server.key -out server.csr
```

Durante a execução do comando ser-lhe-á pedida informação para a identificação do servidor HTTPS. Forneça-a, tendo especial atenção quando lhe for pedido o **Common Name** porque este deverá ser igual ao nome DNS do servidor Web (para este trabalho use www.srsiX.pt, em que o X é o número que lhe ficou atribuído para realizar os trabalhos desta disciplina).

O ficheiro “server.csr” contém o pedido de certificação da chave pública do servidor e deve ser enviado para a CA da qual se pretende o certificado, a CA subordinada que criou num guião anterior. Note que idealmente (e normalmente), o servidor Web não deve residir na mesma máquina que a CA que vai emitir o certificado como, por simplificação, acontece no nosso caso.

1.3 Geração do certificado para o Servidor Web

Usando o XCA, na aba “Certificate Signing Requests” importe o pedido de certificação do Servidor Web. Em seguida dê início ao processo para a sua assinatura. Garanta que o certificado é assinado usando a chave da sua CA, selecione o modelo (template) TLS_server e, depois, pressione no botão “Apply All” para que todas as extensões características de um certificado de Servidor sejam aplicadas ao certificado que vai criar.

Na aba “Subject” garanta que os dados do servidor Web estão corretos, principalmente o CommonName que deverá ser o nome DNS do servidor Web.

Clique o botão “OK” para gerar o certificado.

Pode encontrar o certificado que emitiu para o servidor Web na aba “Certificates”, debaixo do certificado da CA que o assinou. Exporte o certificado usando o formato “PEM chain”, para que contenha também o certificado da CA.

1.4 Instalação do certificado e chave privada no Servidor Web

Para configurar o HTTPS no servidor Web, ativamos o seu módulo SSL/TLS através do comando:

```
$ sudo a2enmod ssl
```

A ativação deste módulo cria automaticamente um par de chaves para o servidor e um certificado auto-assinado da respetiva chave pública; porém, não vamos usar estas credenciais.

Na diretoria /etc/apache2/sites-available está o ficheiro “default-ssl.conf”, que contém a configuração por omissão do SSL usada pelo servidor. Edite e altere este ficheiro para que o servidor Web use a chave privada e o certificado anteriormente criados. Em particular, altere as seguintes variáveis de configuração:

- SSLCertificateKeyFile: nome do ficheiro com a chave privada do servidor.
- SSLCertificateFile: nome do ficheiro com o certificado do servidor.
- SSLCertificateChainFile: nome do ficheiro com o certificado do servidor.

Feitas estas alterações, ative o site e reinicie o servidor usando dos seguintes comandos:

```
$ sudo a2ensite default-ssl.conf
```

```
$ service apache2 restart
```

1.5 Acesso à página inicial do Servidor Web

Na máquina onde instalou o servidor, abra um navegador (browser) e verifique se consegue aceder ao servidor Web usando o URL `https://servername`, em que servername é o nome que colocou no campo CommonName no certificado que gerou para o servidor. Verificará que não consegue aceder ao servidor. Porquê?

Edite o ficheiro `/etc/hosts` e adicione uma linha com o endereço IP localhost (127.0.0.1) e o nome que deu ao servidor no campo `CommonName` do certificado. Tente novamente aceder ao servidor.

Verificará que consegue aceder (no sentido em que ele existe e está contactável), mas obtém uma página a informar um erro do SSL/TLS. Qual o erro indicado?

Analise, no seu navegador, o certificado que o servidor apresentou e a respetiva cadeia de certificação. Qual a razão para o erro que observou?

O problema poderá ser resolvido através da confiança depositada pelos navegadores clientes na CA raiz da cadeia de certificados do servidor. Nesse sentido, os navegadores terão que obter e importar, para o seu repositório de certificados raiz (confiáveis), o certificado da CA raiz de confiança que assinou o certificado da sua CA.

Obtenha o certificado da CA raiz de confiança na pasta da disciplina na plataforma de elearning. No seu navegador, importe esse ficheiro para os certificados raiz de confiança (atenção que nem todos os navegadores usam este nome). Depois da importação, verifique que já conseguirá aceder ao servidor Web que criou sem problemas.

Experimente agora aceder ao servidor usando o endereço `https://127.0.0.1`, que é tecnicamente equivalente ao URL com o nome do servidor. Poderá constatar que obtém novamente o erro que acontecia quando não tinha o certificado da CA Raiz no repositório de certificados de confiança do navegador. Explique a razão para isto acontecer e como deve proceder para resolver o problema.

1.6 Análise da configuração do Servidor Web

A ferramenta `sslttest` permite fazer a análise da configuração do SSL em servidores Web locais (sem ligação à Internet). Instale esta ferramenta na sua máquina, usando o comando `sudo apt-get install testssl.sh`, e analise a configuração do seu servidor.

Como pode ser melhorada a configuração do seu servidor?

1.7 Redirecionamento para HTTPS

É uma boa prática que os servidores Web que suportam HTTPS não atendam aos pedidos feitos através de HTTP. Em vez disso, devem redirecionar o navegador para que este faça o pedido através de HTTPS.

Veja o que são os códigos HTTP e em particular o código HTTP 301. Configure o seu servidor para usar o código HTTP 301 para redirecionar os pedidos HTTP para usar HTTPS. (diretiva `Redirect`)

Indique no relatório como procedeu.

2. Conclusão

Elabore um relatório sobre o trabalho efetuado, que inclua as respostas às questões efetuadas e inclua imagens evidenciando aspetos importantes do trabalho.

1.

1.1)

1.2)

1.3)

1.4)

1.5)

1.6)

1.7)

Useful links:

<https://www.youtube.com/watch?v=TLUNnz5C4bY&t=181s>

<https://www.youtube.com/watch?v=PlfTlrpUR-M>

<https://www.youtube.com/watch?v=5qecyZHL-GU&t=40s>

<https://unit42.paloaltonetworks.com/wireshark-tutorial-decrypting-https-traffic/>

<https://wiki.wireshark.org/TLS>

<https://clouddocs.f5.com/training/community/adc/html/class4/module1/lab11.html>